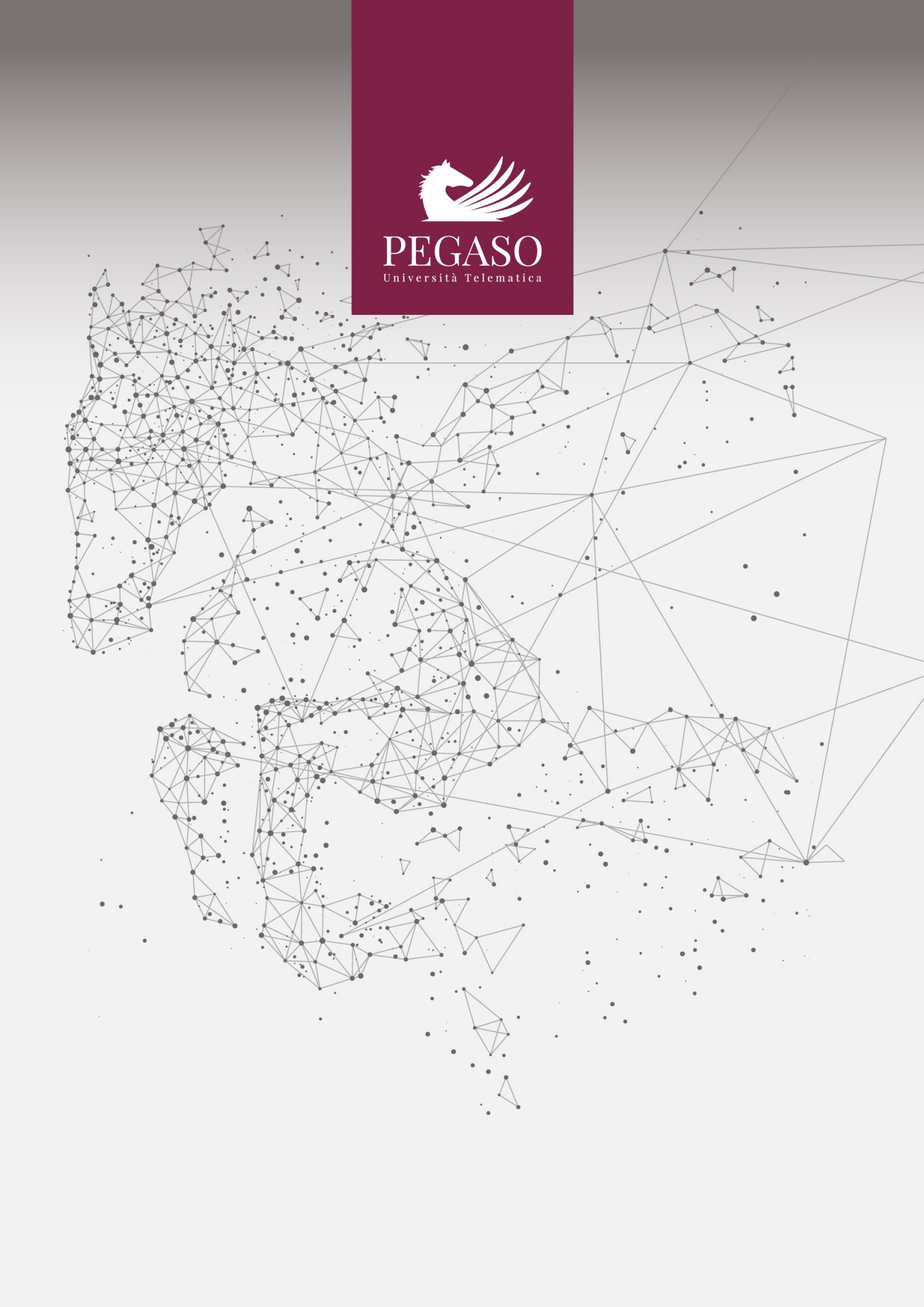

PEGASO
Università Telematica

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1. DISTRIBUZIONE DELLE CHIAVI PUBBLICHE 3
2. DISTRIBUZIONE DELLE CHIAVI SEGRETE 7
3. LO SCAMBIO DI CHIAVI DIFFIE-HELLMAN 9
BIBLIOGRAFIA 13

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1. Distribuzione delle chiavi pubbliche

Uno dei principali ruoli della crittografia a chiave pubblica, oltre a quello della cifratura dei messaggi scambiati fra due soggetti, è quello di fungere da strumento per distribuire le chiavi segrete per la crittografia simmetrica. Detto ciò, bisogna quindi prima risolvere il problema della distribuzione delle chiavi pubbliche fra i soggetti che vogliono instaurare una comunicazione cifrata.

Esistono sostanzialmente 4 schemi generali:

- *Annuncio pubblico*
- *Elenco pubblico*
- *Autorità di distribuzione delle chiavi*
- *Certificati a chiavi pubbliche*

Annuncio pubblico

Questo è il caso sicuramente più semplice, in cui un utente trasmette in maniera diretta (all'utente con cui vuole comunicare) o broadcast (a vari utenti in generale) la propria chiave pubblica. Tale metodo è certamente molto comodo e immediato ma presenta un evidente punto debole: un utente B può infatti fingere di essere un altro (utente A) ed inviare per suo conto una chiave pubblica PU_a ad altri utenti con cui l'utente A vuole dialogare. L'utente B ("finto utente A") è così in grado di decifrare tutti i messaggi destinati all'utente A.

Elenco pubblico

In questo caso, si utilizza un elenco dinamico e pubblico che contiene tutte le chiavi pubbliche:

- Livello di sicurezza superiore rispetto all'annuncio pubblico, in quanto le chiavi si trovano nella lista in maniera visibile

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- Necessità di un'organizzazione fidata la quale ha il compito di mantenere e distribuire l'elenco (non si occupa di distribuire le chiavi, come avviene invece nel caso successivo presentato di seguito!)
- Necessità di funzionalità per gli utenti di gestione/aggiornamento delle chiavi
- Pericolo se:
  - la chiave privata dell'autorità che gestisce l'elenco viene violata
  - i registri stessi sono violati

Autorità di distribuzione delle chiavi pubbliche

In questo caso la sicurezza viene aumentata ulteriormente dalla presenza di un'autorità centrale che si occupa della gestione e distribuzione delle chiavi pubbliche degli utenti che conoscono la chiave pubblica dell'autorità

1. L'utente A invia un timestamp T_1 e richiede la chiave pubblica dell'utente B con cui vuole instaurare una comunicazione sicura
2. L'autorità risponde con un messaggio cifrato con la propria chiave privata PR_{auth} e ciò garantisce che proviene dall'autorità centrale; tale messaggio contiene la chiave pubblica dell'utente B (PU_b) e il timestamp T_1 inviato dall'utente A:

   $E(PR_{auth}, [PU_b \,||\, T_1])$
3. L'utente A decifra il messaggio con la chiave pubblica dell'autorità centrale, è garantito dalla presenza del timestamp che tale messaggio non è una replica e ottiene la chiave pubblica PU_b dell'utente B
4. L'utente A invia all'utente B un messaggio cifrato con PU_b contenente il suo identificativo e un nonce N_1:

   $E(PU_b, [ID_A \,||\, N_1])$
5. L'utente B decifra il messaggio con la propria chiave privata PR_b e richiede all'autorità centrale, analogamente a quanto fatto dall'utente A, la chiave pubblica dell'utente A.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

6. L'utente B invia un messaggio cifrato con la chiave pubblica dell'utente A contenente il nonce N_1 ricevuto in precedenza concatenato con un nuovo nonce N_2:

   $E(PU_a, [N_1 || N_2])$

7. In risposta l'utente A invia:

   $E(PU_b, N_2)$

   Se A e B salvano le chiavi pubbliche dell'altro, la prima parte di dialogo non va più ripetuta.

Certificati a chiave pubblica

Nel caso di distribuzione mediante autorità, ogni utente vi deve fare riferimento per ottenere le chiavi pubbliche degli altri, inoltre esiste sempre un problema di vulnerabilità dell'autorità stessa.

L'impiego di certificati, che gli utenti possono scambiarsi fra di loro, evita di dover contattare un'autorità di distribuzione delle chiavi.

Un certificato viene rilasciato da un'autorità di certificazione e consiste di:

- una chiave pubblica
- l'identificatore del proprietario
- la firma di garanzia dell'autorità di certificazione

L'utente A fornisce (mediante un canale autenticato) all'autorità di certificazione la propria chiave pubblica PU_a e riceve un certificato C_a che può utilizzare per dialogare con gli altri utenti.

Tale certificato ha la seguente forma:

$C_a = E(PR_{auth}, [T_1 || ID_A || PU_a])$

Esso contiene un messaggio cifrato con la chiave privata PR_{auth} dell'autorità di certificazione che è composto da un timestamp, l'identificativo dell'utente possessore del certificato e la sua chiave pubblica

La cifratura con la chiave privata dell'autorità di certificazione PR_{auth} garantisce sulla autenticità del certificato, mentre il timestamp T_1 garantisce che il certificato sia aggiornato

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

X.509 è lo schema accettato per i certificati (e.g. usato in applicazioni come IPSec, SET, S/MIME).

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. Distribuzione delle chiavi segrete

Una volta che le chiavi pubbliche sono state distribuite si può cominciare ad usarle. Ovviamente la crittografia asimmetrica (chiave pubblica) serve per cifrare i messaggi ma è usata però generalmente per trasferire la chiave segreta per la crittografia simmetrica in quanto questa si presenta sostanzialmente più veloce.

Esistono fondamentalmente due metodologie di distribuzione della chiave segreta:

- *Distribuzione semplice della chiave segreta*
- *Distribuzione della chiave segreta con segretezza e autenticazione*

Distribuzione <u>semplice</u> della chiave segreta

1. L'utente A invia un messaggio all'utente B che contiene la propria chiave pubblica PU_a e il suo identificativo ID_A (e.g. il proprio certificato C_a)
2. L'utente B genera una chiave segreta K_s e la invia all'utente B cifrata con PU_a; l'utente A con la sua chiave privata PR_a decifra (solo lui è in grado di farlo!) il messaggio ed entra in possesso della chiave K_s (segreto condiviso).
3. Se la coppia di chiavi PU_a/ PR_a è stata creata per questo compito viene cancellata

Tale sistema di distribuzione può però essere sottoposto **all'*attacco man-in-the-middle***; vediamo di cosa si tratta.

1. L'utente A invia un messaggio all'utente B: $\{PU_a \mid\mid ID_A\}$
2. L'attaccante E lo intercetta, ci sostituisce la propria chiave pubblica e invia all'utente B il seguente messaggio: $\{PU_e \mid\mid ID_A\}$
3. L'utente B genera una chiave segreta K_s e risponde con $E(PU_e,K_s)$
4. L'attaccante E intercetta la risposta ottiene la chiave segreta K_s leggendo il messaggio con la sua chiave privata, poi invia la chiave segreta K_s cifrata con la chiave pubblica dell'utente A all'utente A stesso: $E(PU_a,K_s)$

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

A questo punto gli utenti A e B condividono regolarmente la chiave segreta K_s ma non sanno che anche l'attaccante E la possiede e può in maniera passiva decifrare le loro comunicazioni.

Distribuzione della chiave segreta con segretezza e autenticazione

Per ovviare all'attacco *man-in-the-middle* si deve eseguire una diversa distribuzione della chiave segreta che prevede una fase iniziale di autenticazione reciproca degli utenti A e B:

1. L'utente A invia un messaggio all'utente B: $E(PU_b,[N_1 \,||\, ID_A])$
2. L'utente B lo decifra (solo lui può farlo) e a sua volta invia all'utente A: $E(PU_a,[N_1 \,||\, N_2])$ la presenza di N_1 garantisce l'utente A che sta parlando con l'utente B
3. L'utente A lo decifra e risponde con: $E(PU_b, N_2)$, la presenza di N_2 garantisce l'utente B che sta parlando con l'utente A
4. A questo punto l'utente A genera la chiave segreta K_s e la invia all'utente B: $E(PU_b,E(PR_a, K_s))$ solo l'utente B può decifrare tale messaggio e il fatto che K_s sia cifrata con la chiave privata dell'utente A garantisce che solo lui può averla inviata.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3. Lo scambio di chiavi Diffie-Hellman

Questo algoritmo basato sulla crittografia a chiave pubblica è dovuto a Diffie e Hellman e consente a due utenti di scambiarsi in sicurezza una chiave che possa essere utilizzata per crittografare ulteriori messaggi. Tale algoritmo deve la sua efficacia alla difficoltà del calcolo dei *logaritmi discreti*.

Definiamo cosa si intende per logaritmo discreto e, prima di tutto, per radice primitiva di un numero primo

La **radice primitiva** di un numero primo *p* è un numero le cui potenze modulo *p* generano tutti gli interi compresi tra *1* e *p-1* ovvero:

- se *a* è radice primitiva di *p*, allora i numeri *a* mod *p*, a^2 mod *p*, . . . , a^{p-1} mod *p* sono distinti e sono costituiti dagli interi compresi tra *1* e *p-1* in una certa permutazione.

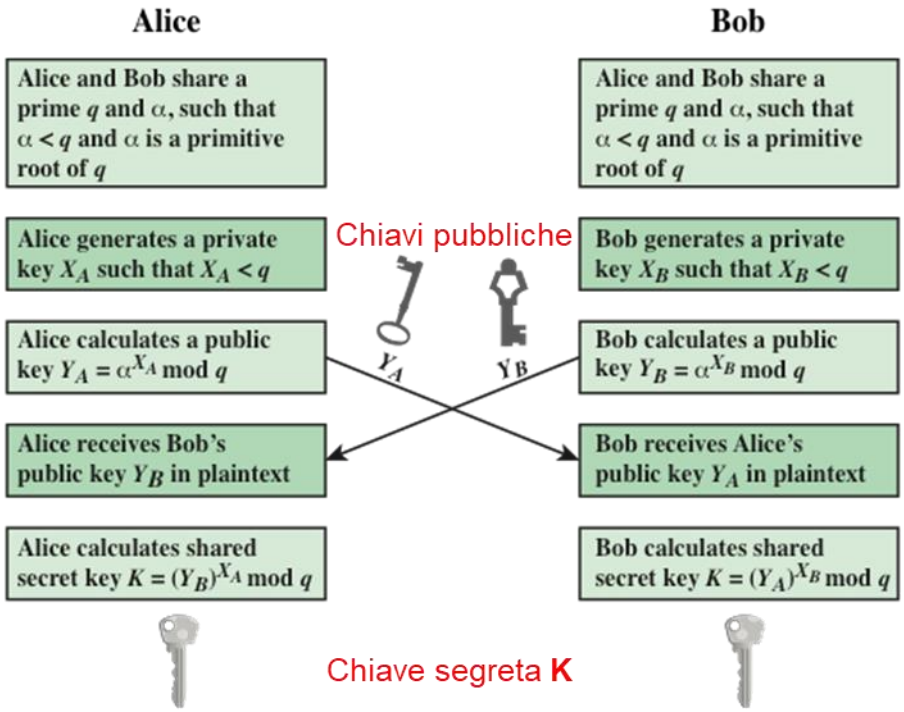
Dato un qualsiasi intero *b* e una radice primitiva *a* di un numero primo *p* è possibile trovare un esponente univoco *i* tale che:

- $b = a^i \mod p$ dove $0 \leq i \leq (p - 1)$

L'esponente *i* è chiamato **logaritmo discreto** di *b* per la base *a* modulo *p*, cioè $i = \text{dlog}_{a,p}(b)$.

Definito ciò, vediamo come avviene lo scambio di chiavi Diffie-Hellman (vedi figura sottostante).

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



Il numero primo *q* e l'intero *a* sono pubblicamente noti, con *a* < *q* e con *a* che è una radice primitiva di *q*; mentre X_A e X_B sono due interi casuali privati (chiavi private).

Alice genera l'intero casuale X_A che costituisce la sua chiave privata tale che $X_A < q$ e poi calcola la sua chiave pubblica Y_A tale che $Y_A = a^{(X_A)} \ mod \ q$. Lo stesso fa Bob generando X_B e calcolando Y_B.

Y_A e Y_B sono le chiavi pubbliche che Alice e Bob si scambiano e con cui possono effettuare entrambi rispettivamente il seguente calcolo:

Alice: $K = (Y_B)^{(X_A)} \ mod \ q$

Bob: $K = (Y_A)^{(X_B)} \ mod \ q$

$(Y_B)^{(X_A)} \ mod \ q = [a^{(X_B)} \ mod \ q]^{(X_A)} \ mod \ q = [a^{(X_B \, X_A)}] mod \ q = [a^{(X_A)} \ mod \ q]^{(X_B)} \ mod \ q = (Y_A)^{(X_B)} \ mod \ q$

L'uguaglianza è verificata in quanto per le proprietà dell'aritmetica modulare vale che $(a \ mod \ q)(b \ mod \ q) = (ab \ mod \ q)$.

Le due parti si sono così scambiate la chiave segreta **K.**

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Un eventuale attaccante deve calcolare X_A e/o X_B noti q, α, Y_A e Y_B, cioè deve risolvere il logaritmo discreto di $X_B = dlog_{(\alpha,q)}(Y_B)$.

Calcolare il log discreto è molto difficile (impossibile per numeri primi q estesi) invece calcolare dei valori esponenziali modulo un numero primo è relativamente facile.

Vediamo un esempio numerico: $q=353$ e $\alpha=3$, selezioniamo $X_A=97$e $X_B=233$ (chiavi private) e calcoliamo le chiavi pubbliche

$$Y_A = 3^{97} \; mod \; 353 = 40$$

$$Y_B = 3^{233} \; mod \; 353 = 248$$

Poi calcolano entrambi la chiave segreta **K** eseguendo le seguenti operazioni:

$$\mathrm{K} = 248^{97} \; mod \; 353 = 160$$

$$\mathrm{K} = 40^{233} \; mod \; 353 = 160$$

In questo semplice esempio un attaccante può violare l'algoritmo con un attacco a forza bruta risolvendo, per esempio, le equazioni:

$$3^i \; mod \; 353 = 40$$

oppure

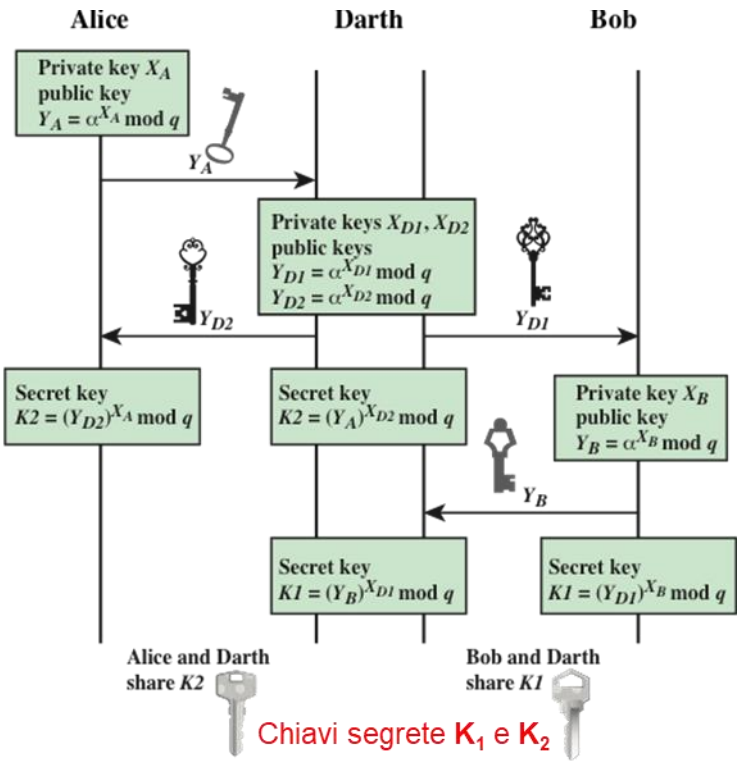
$$3^i \; mod \; 353 = 248$$

così da scoprire una delle chiavi private.

L'**attacco man-in-the-middle** è in grado di violare lo scambio Diffie-Hellman in quanto i partecipanti non sono autenticati (vedi figura).

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



- L'attaccante Darth genera due chiavi private X_{D1} e X_{D2} e le corrispondenti chiavi pubbliche Y_{D1} e Y_{D2}
- Invia Y_{D2} ad Alice in risposta a Y_A e inoltra Y_{D1} a Bob che risponde con Y_B
- Alla fine, Alice e Darth condividono K_2 e Darth e Bob condividono K_1

Il risultato finale è che le comunicazioni tra Alice e Bob sono compromesse e Darth può eseguire i seguenti attacchi:

- *Attacco passivo*: Darth con la chiave K_2 può decifrare i messaggi di Alice verso Bob e inoltrarli a Bob codificati con K_1
- *Attacco attivo*: Darth con la chiave K_2 può decifrare i messaggi di Alice verso Bob, **modificarli** e inoltrarli a Bob codificati con K_1

Vale ovviamente anche il viceversa da Bob verso Alice.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: Capitoli 10.
- "Cryptography and Network Security", 7/ed, William Stallings, Pearson.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).